Passive vs. Active Reconnaissance Analysis: example.com

This document highlights the methodologies and findings derived from the reconnaissance phases conducted against example.com, comparing the non-intrusive data collection of passive footprinting with the direct system interaction of active enumeration.

Passive Reconnaissance Methodology and Findings

Passive reconnaissance was executed without sending direct traffic to the target's primary servers, utilizing open-source intelligence (OSINT) and public registries to ensure the investigation remained undetected by the target's security infrastructure.

1. Domain and Infrastructure Registry: WHOIS queries established that the domain was initially registered on August 14, 1995, and is currently hardened with clientDeleteProhibited, clientTransferProhibited, and clientUpdateProhibited status locks.

2. DNS Enumeration: The target leverages Cloudflare's infrastructure, utilizing the authoritative nameservers hera.ns.cloudflare.com and elliott.ns.cloudflare.com. The root domain resolves to the primary IPv4 addresses 172.66.147.243 and 104.20.23.154, alongside corresponding IPv6 addresses.

3. Email Security and Identity OSINT: An SPF TXT record is configured with a strict -all policy to automatically reject unauthorized outbound mail senders. Furthermore, email harvesting utilizing DuckDuckGo, Yahoo, and crt.sh successfully exposed three corporate addresses: name@example.com, test@example.com, and user@example.com.

4. Web Footprinting: Web metadata analysis confirmed the presence of Cloudflare proxies, active caching mechanisms (cf-cache-status: HIT), and restrictive HTTP configurations limiting allowed methods to GET and HEAD.

Active Reconnaissance Methodology and Findings

Active reconnaissance involved transmitting direct network probes to the target's infrastructure (104.20.23.154) to map the live attack surface. Unlike passive methods, this phase generates direct traffic that is typically recorded in the target's firewall and server logs.

1. Host Discovery: Initial ICMP sweeps confirmed the target host is live, returning a response latency of 0.096 seconds.

2. Port and Service Enumeration: Comprehensive service version scanning identified six explicitly open TCP ports exposed to the external network.

3. Web Services: Plaintext HTTP traffic is permitted on ports 80 and 8080, while secure HTTPS traffic is facilitated on ports 443 and 8443. All identified web services are actively proxied through Cloudflare.

4. Exposed Peripheral Services: Port 21 (typically FTP) and port 587 (message submission) were found open to the public internet, though the specific underlying service versions remained filtered or unresponsive to deeper fingerprinting.

Comparative Assessment

The passive reconnaissance phase successfully mapped the administrative hierarchy, historical timeline, and foundational DNS architecture of example.com entirely through third-party records. In contrast, the active reconnaissance phase provided an accurate, real-time topological map of the external attack surface, identifying specific unencrypted services and live web ports by directly engaging the target's network boundary.